SIZMA TESTİ RAPORU

Rapor Tarihi	21/10/2026
Hazırlayan	Ömer Faruk Baysal
Test Hedefi	PortSwigger Web Academy Lab

1. 2FA bypass

Bu raporda, PortSwigger Web Security Academy'de yer alan 2FA simple bypass konusuyla ilgili durum tek bir bulgu altında ele alınmıştır.

2. Yönetici Özeti

Yapılan güvenlik testinde, hedef uygulamanın iki faktörlü kimlik doğrulama (2FA) mekanizmasının sunucu tarafında zorunlu kılınmadığı tespit edilmiştir. Kullanıcı adı ve parola doğrulandıktan sonra, ikinci doğrulama adımı (tek kullanımlık kod) tamamlanmadan korunan hesap sayfasına doğrudan erişilebildiği gözlemlenmiştir. Bu durum, kurbanın parolasını ele geçirmiş bir saldırganın 2FA korumasını tamamen atlayarak hedef hesabı ele geçirmesine imkân tanıdığından, zafiyetin ivedilikle giderilmesi önerilmektedir.

3. Zafiyet Açıklaması

Hedef uygulamada giriş işlemi iki adımdan oluşmaktadır: önce kullanıcı adı ve parola doğrulanmakta, ardından kullanıcıdan tek kullanımlık bir doğrulama kodu (2FA) istenmektedir. Ancak sunucu, korunan sayfalara erişimde ikinci adımın (kod doğrulaması) tamamlanıp tamamlanmadığını denetlememektedir. Kullanıcı adı ve parola doğrulandığı anda oturum “giriş yapmış” sayıldığından, doğrulama kodu hiç girilmeden doğrudan hesap sayfasına (/my-account) erişilebilmektedir. Dolayısıyla ikinci faktör yalnızca arayüzde bir adım olarak sunulmakta, sunucu tarafında bir güvenlik kontrolü olarak uygulanmamaktadır.

4. Risk Seviyesi

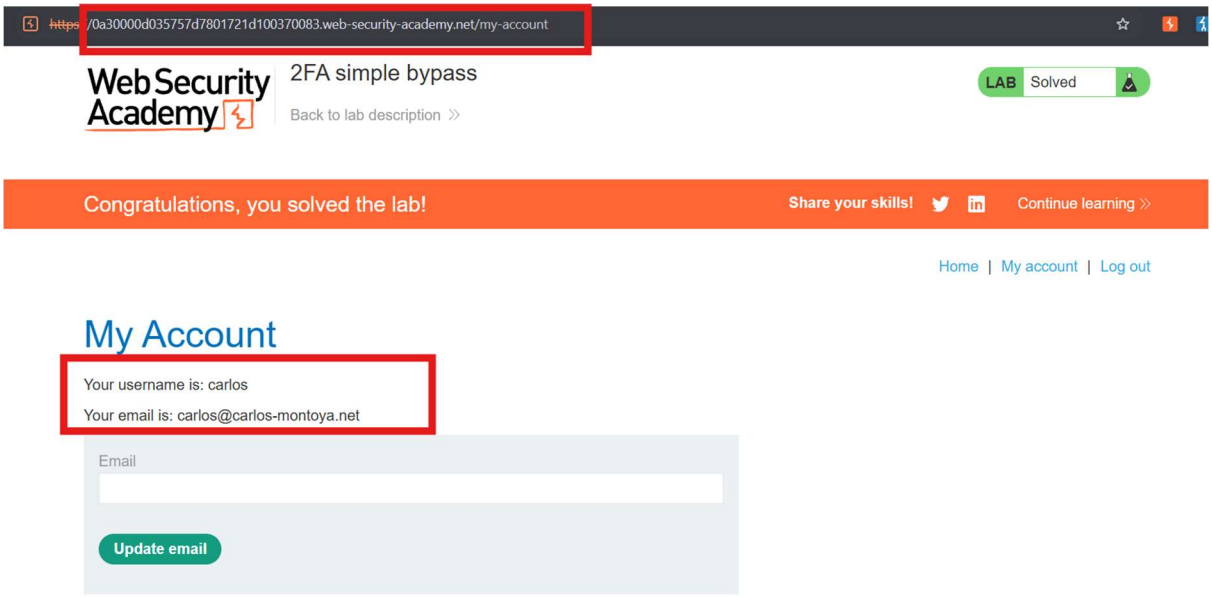
Risk Seviyesi	Yüksek
CVSS v3.1 Skoru	7.4
CVSS v3.1 Vektörü	AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N
CWE	CWE-287 (Improper Authentication)

5. Etki

Yapılan testler sonucunda, hedef kullanıcının parolasını ele geçirmiş bir saldırgan, iki faktörlü doğrulama adımını hiç tamamlamadan kurbanın hesabına tam erişim sağlayabilmektedir. Doğrulanan etki, 2FA korumasının tamamen atlatılarak hedef hesabın ele geçirilmesi; hesaptaki kişisel bilgilerin görüntülenmesi ve hesap üzerinde değişiklik yapılabilmesidir. 2FA'nın varlık amacı parolası çalınmış hesapları korumaktır; bu kontrol işlevsiz olduğundan, parola sızıntısı doğrudan hesap ele geçirmeye dönüşmektedir.

6. Proof Of Concept

Hedef uygulamada verilen kimlik bilgisiyle giriş yapıldığına doğrulama kod ekranı görülmektedir. Test amacıyla /my-account uzantılı adrese gidildiğinde giriş yapılabildiği görülmektedir. Yani istenen doğrulama kodunun kontrol edilmediği gözlemlenmektedir.



7. Çözüm Önerisi

İkinci kimlik doğrulama faktörü (2FA), yalnızca arayüzde bir adım olarak değil, sunucu tarafında zorunlu bir güvenlik kontrolü olarak uygulanmalıdır. Kullanıcı adı ve parola doğrulandıktan sonra oturum "tam yetkili" sayılmamalı; "2FA bekliyor" gibi ara bir durumda tutulmalı ve bu durumdaki bir oturumla hiçbir korumalı kaynağa (hesap sayfası, API uçları vb.) erişim verilmemelidir. Korumalı her istekte, oturumun ikinci doğrulama adımını başarıyla tamamlamış olduğu sunucu tarafında doğrulanmalıdır.

8. Sonuç

Yapılan testler sonucunda, hedef uygulamanın iki faktörlü doğrulama mekanizmasının sunucu tarafında zorunlu kılınmadığı ve ikinci adım atlanarak korunan hesaba doğrudan erişilebildiği doğrulanmıştır. Bu durum, 2FA'nın sağlaması gereken korumayı tamamen işlevsiz bırakmakta ve parolası ele geçirilmiş hesapların doğrudan ele geçirilmesine yol açmaktadır. İkinci faktörün sunucu tarafında zorunlu bir kontrol olarak uygulanmasıyla zafiyetin giderilmesi önerilmektedir.